

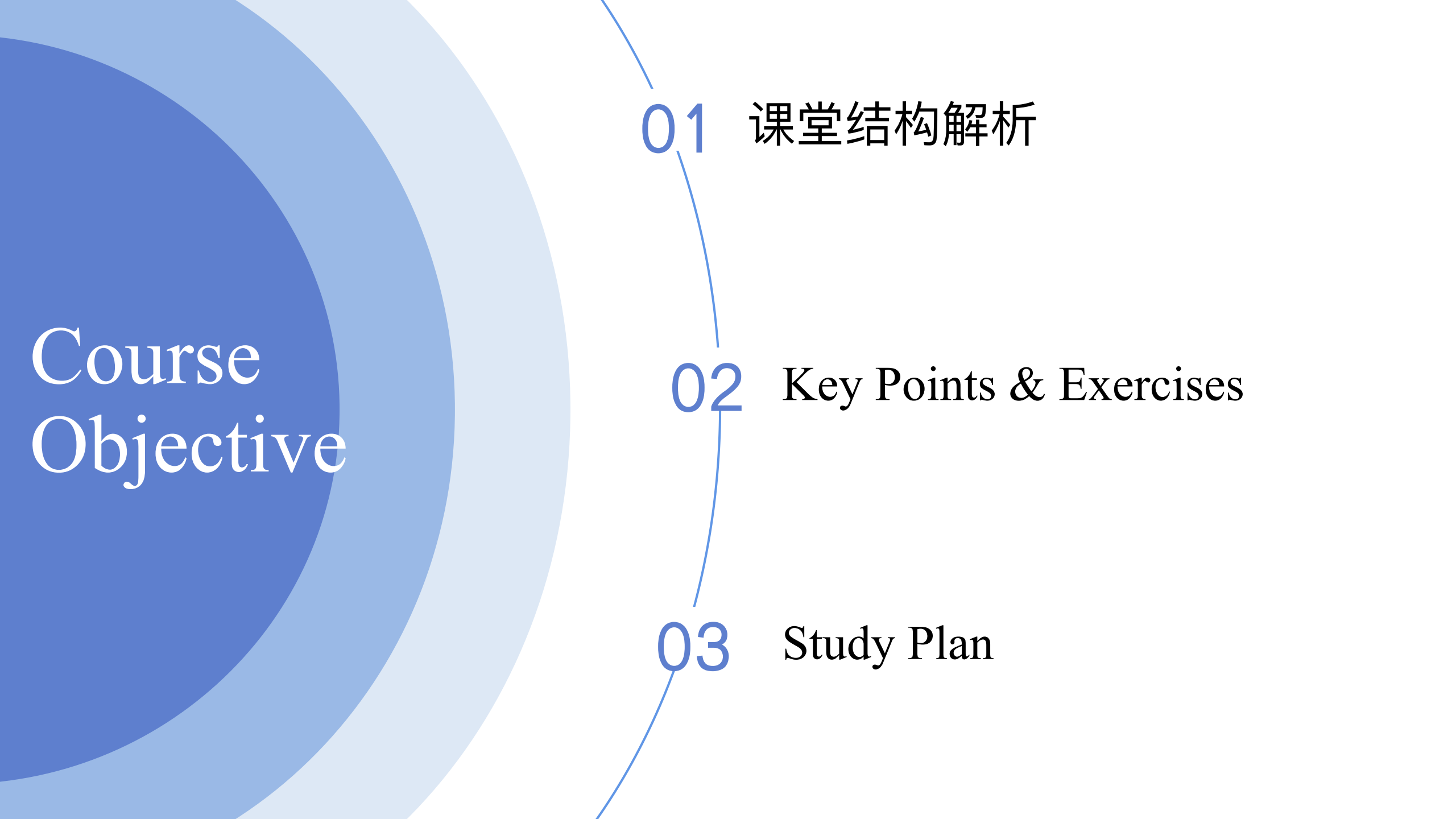


COMP3052

Computer Security

讲师: n_n





Course Objective

01 课堂结构解析

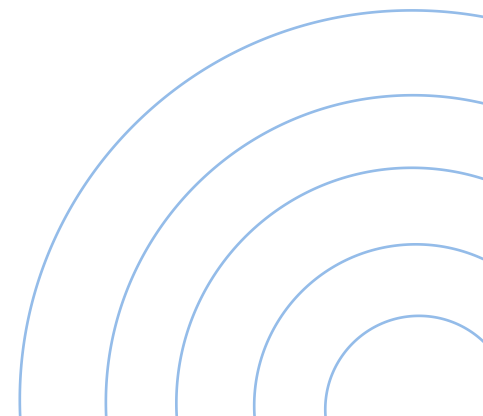
02 Key Points & Exercises

03 Study Plan

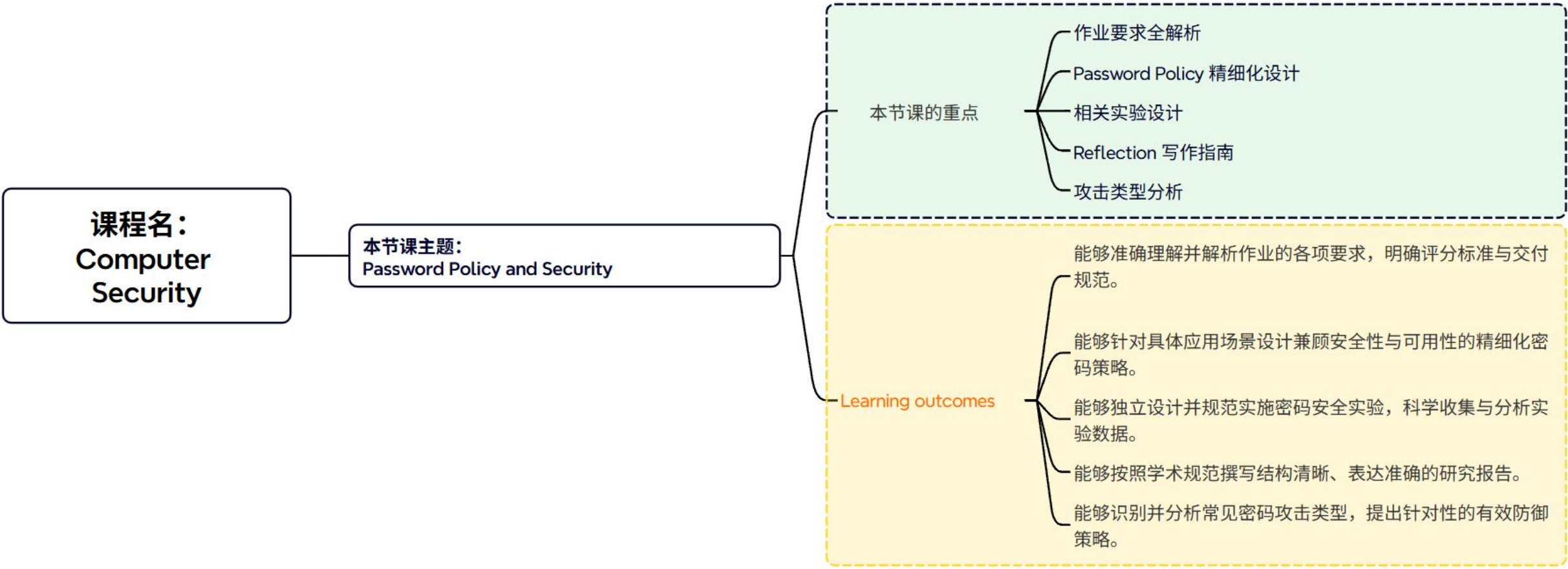


PART 01

课堂结构解析



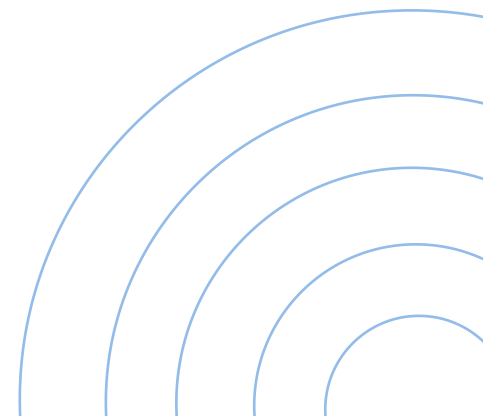
➤ 课堂结构解析





PART 02

Key Points & Exercises



1.COMP3052.SEC-Coursework01

Basic Information

课程与作业：COMP3052 Computer Security, Coursework 01（占比20%），主题为密码安全实验报告

字数要求：正文900-1100词（参考文献、附录不计入）

提交要求：文件名[学号]_report.pdf，封面含姓名、学号、课程代码、日期、字数；Moodle平台提交，截止时间2026年4月6日周一18:00

Task Details

1. Develop Password Policy-制定Password Policy

列出并详细说明密码规则（长度、复杂度、有效期、复用限制、历史记录等），可补充额外认证手段并说明理由。

2. Strategic rationality demonstration-策略合理性论证

结合个人实验证据（附录附原创截图，禁止复用实验室素材）+ 权威学术/行业文献/白皮书，逐条佐证每条策略的科学性。

3. Personal Experiment Reflection-个人实验反思

阐述实验如何影响策略制定、遇到的难点与收获、未来优化方向，体现主观思考与实践关联。

Task Details

4.Defense Attack Explanation-防御攻击说明

明确该策略针对的主流密码攻击类型（如暴力破解、字典攻击、撞库攻击等）。

5.Expand experimental research-拓展实验研究

完成课堂外自主实验（如测试密码强度工具、模拟攻击场景、编写策略评估脚本等），附代码、结果截图佐证。

可选用任意登录处进行课堂外自主实验，来模拟攻击者进行密码爆破的场景
(比如dvwa登录框爆破、ssh爆破、rdp爆破等)

Marking Criteria-评分标准

1.基础信息与格式（10%）

考核文件名、封面、结构、提交规范的合规性。

2.策略罗列与说明（10%）

要求规则清晰全面、技术表述严谨。

3.策略客观论证（30%）

重点评估实验证据+权威文献的支撑力度与技术准确性。

4.主观反思与实践（30%）

强调个人洞察、实验与策略的关联性深度。

5.拓展实验成果（20%）

考察自主实验设计、截图与成果的完整性，需超出基础实验要求。

2.什么是Password Policy--密码策略？

密码策略是身份认证体系的核心防线，旨在通过对账户密码创建、存储、使用、更新及注销全生命周期的强制性规则管控，杜绝弱密码与复用风险。

Password strategy is the core defense line of the identity authentication system, aimed at controlling the entire lifecycle of account password creation, storage, use, update, and cancellation through mandatory rules, and eliminating weak passwords and reuse risks.

设计维度	核心内容与规格	安全价值
定义范畴	覆盖密码创建、存储、使用、更新、销毁的全生命周期规则集	建立标准化的身份认证安全基准，消除管理盲区。
核心目标	杜绝弱口令、规避密码复用、降低泄露风险、平衡安全与体验	在攻击成本（破解难度）与管理效能间达成平衡。
设计原则	安全优先、兼顾易用、对标合规、动态防御	确保策略既能抵御现代攻击，又符合行业监管要求。
对标标准	NIST SP 800-63B 数字身份指南、ISO 27001 管理体系	深度对标国际权威基准，确保存量与增量数据的合规。



Key Points

密码策略核心细则（一）

2.1 密码长度要求（Password Length Requirements）

采用分级长度管控，区分普通用户与高权限账户，适配不同安全等级：普通终端用户密码最小长度12位，禁止10位及以下；管理员/高权限账户最小长度16位，提升核心防护门槛；设计依据：现代GPU可快速破解8-10位短密码，12位以上大幅提升暴力破解成本，16位常规算力几乎无法破解。

2.2 密码复杂度要求（Password Complexity Requirements）

采用混合字符组合规则，杜绝单一字符类型密码：必须包含大写/小写字母、数字、特殊符号四类中的至少三类；禁止连续重复/顺序/键盘相邻字符；禁止嵌入个人身份信息（姓名、生日、工号等）。



密码策略核心细则（二）

2.3 密码有效期（Password Expiration Policy）

摒弃无差别定期修改模式，采用动态有效期机制：普通用户最长90天，提前7天提醒；高权限/高风险账户最长45天，到期未改自动锁定；已开启MFA的账户有效期可延长至120天。

2.4 密码重用限制（Password Reuse Restrictions）

禁止重用最近5次历史密码，杜绝循环使用；系统自动校验相似度，禁止单字符修改旧密码；历史密码加密存储，仅用于校验，禁止明文留存。



Key Points

密码策略核心细则（三）

2.5 账户锁定机制（Account Lockout Mechanism）

针对暴力破解设计阈值锁定+日志审计：连续输错5次临时锁定15分钟；单日累计输错10次永久锁定，需管理员人工解锁并核查日志；锁定记录实时写入安全日志，留存IP、时间、错误次数。

2.6 弱密码禁止（Weak Password Prohibition）

内置标准化弱密码字典，覆盖全球常见弱密码（如123456、password）；禁止使用系统名、业务名、机构名等关联词汇；用户注册/修改时实时校验，拒绝弱密码并提示修改。



密码策略核心细则（四）

2.7 多因素认证（Multi-Factor Authentication, MFA）

强制要求：所有管理员、高权限账户必须开启MFA；推荐要求：普通用户登录敏感系统/访问核心数据时强制开启；支持方式：APP令牌、短信/邮箱验证、硬件安全密钥；核心价值：密码泄露后无第二因子仍无法登录，降低账户被盗风险90%以上。

3.Policy标准化写作方法：Rule + Reason + Attack

3.1 三段式定义与写作要求

Rule（规则）：精准、量化、无歧义描述策略要求，明确“必须做什么、禁止做什么”，可直接落地执行

Rule: Accurately, quantitatively, and unambiguously describe strategic requirements, clarify "what must be done and what is prohibited", and can be directly implemented

Reason（原因）：结合安全理论、行业标准、用户体验、技术现状，说明规则设计的必要性与合理性

Reason: Combining security theory, industry standards, user experience, and technological status, explain the necessity and rationality of rule design

Attack（防御攻击）：明确该规则可抵御的具体攻击类型，阐述防护原理，体现策略安全价值

Attack: Clearly define the specific types of attacks that the rule can resist, explain the principles of protection, and demonstrate the security value of the strategy

3.2 标准化模板与示例

写作模板：

Rule：[精准描述规则内容]

Reason：[结合标准/理论/算力说明设计依据]

Attack：[抵御的攻击类型+防护效果]

Writing Template:

Rule: [Accurately describe the content of the rule]

Reason: [Design Basis Based on Standards/Theory/Computing Power Explanation]

Attack: [type of attack resisted+protective effect]

实操示例：

Rule：普通用户密码最小长度为12位，管理员账户密码最小长度为16位。

Reason：根据NIST SP 800-63B密码安全标准，12位混合字符密码可抵御现代常规算力暴力破解；管理员账户权限更高，需提升长度进一步增加破解成本。

Attack：有效抵御暴力破解、字典攻击、彩虹表攻击，大幅延长破解耗时，使其超出攻击者可承受范围。

Practical example:

Rule: The minimum length for a regular user password is 12 digits, and for an administrator account password it is 16 digits.

Reason: According to the NIST SP 800-63B password security standard, a 12 bit mixed character password can resist modern conventional brute force attacks; The administrator account has higher permissions and needs to increase its length to further increase the cost of cracking.

Attack: Effectively resists brute force attacks, dictionary attacks, and rainbow table attacks, significantly prolonging the cracking time and making it beyond the attacker's affordability.

3.3 写作避坑指南

- 每条规则独立撰写，避免多条规则混杂，便于评分者查阅打分
 - Reason部分优先引用NIST、ISO等权威标准，提升专业性
 - Attack部分需精准对应，不夸大防护效果，贴合实际攻击原理
 - 避免模糊表述（如“密码要足够长”“密码尽量复杂”），全部采用量化指标
-
- Each rule is independently written to avoid mixing multiple rules, making it easier for evaluators to review and score
 - Prioritize referencing authoritative standards such as NIST and ISO in the Reason section to enhance professionalism
 - The Attack section needs to be accurately matched, without exaggerating the protective effect, and in line with the actual attack principle
 - Avoid vague statements (such as "passwords should be long enough" and "passwords should be as complex as possible"), and use quantitative metrics for all

4 实验设计

实验核心目的是验证密码策略的有效性，需遵循“控制单一变量、设置对照组、重复实验、记录完整数据”原则，选用简易可行的工具，确保实验可操作、数据可采信，推荐3组核心对照实验：

The core purpose of the experiment is to verify the effectiveness of the password strategy, which should follow the principle of "controlling a single variable, setting a control group, repeating the experiment, and recording complete data". Simple and feasible tools should be selected to ensure that the experiment is operable and the data is reliable. Three core control experiments are recommended:

➤ Exercise

1.弱密码 vs 强密码对比实验

Weak Password vs Strong Password Comparison Experiment

实验目的：验证强密码策略对字典攻击的防御效果

Experimental objective: To verify the defense effect of strong password strategy against dictionary attacks

实验变量：自变量为密码类型（弱密码、强密码），因变量为破解耗时、破解成功率

实验分组：对照组（弱密码：123456、password、admin、qwerty）；实验组（强密码：混合字符T9#kLp2@vX1q、16位混合字符）

实验工具：John the Ripper、Hydra（仅限课程实验虚拟机使用，严禁用于真实系统）

➤ Exercise

实验步骤：搭建本地测试环境→导入测试密码→运行字典攻击→记录破解耗时、尝试次数、结果→重复3次取平均值

预期结果：弱密码可在1秒-5分钟内破解，强密码在24小时内无法破解

Expected result: Weak passwords can be cracked within 1-5 minutes, while strong passwords cannot be cracked within 24 hours

强弱密码hash

```
文件(F) 编辑(E) 搜索(S) 视图(V) 文档(D) 帮助(H)
1 weak1:$6$doZmv5Xn.QyI6Ygq$BuhgoLidZXY1/e/5YvLV0EzPk1VnTBRLvL6Yr.2Ai6D1IpDeCOE/mbT/
  tQ0DF6coJBXfFwVNVCTkprM6RdDet1
2 weak2:$6$CnFlForzV1vtITvT$5Z07U3ds8YNrXqQcJ0vnBYnAuuD7bMEv0WV/
  HHC1I.wqa6I3VsPB60gDrRBXJk2DNZadSrFPC9ldwJzeGmLK01
3 user3:$6$0mk8KYrmdebehQWH$Eutw666C5bnvq04SefTi5viuv7ZmfZf.FD9fL4JVbuN9ji8u1.TgUp41gZp0yACKcNa3H-
  Le4uw0SWjC9jGztb1
4
5
```

```
(fofo@fofo)-[~/桌面]
$ time john --wordlist=/usr/share/wordlists/rockyou.txt test.txt
Warning: detected hash type "sha512crypt", but the string is also recognized as "H
MAC-SHA256"
Use the "--format=HMAC-SHA256" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 3 password hashes with 3 different salts (sha512crypt, crypt(3) $6$ [SHA512
256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
123456 (weak1)
admin (weak2)
```

2.密码长度对比实验

Password Length Comparison Experiment

实验目的：验证密码长度与安全强度的正相关性

Experimental objective: To verify the positive correlation between password length and security strength

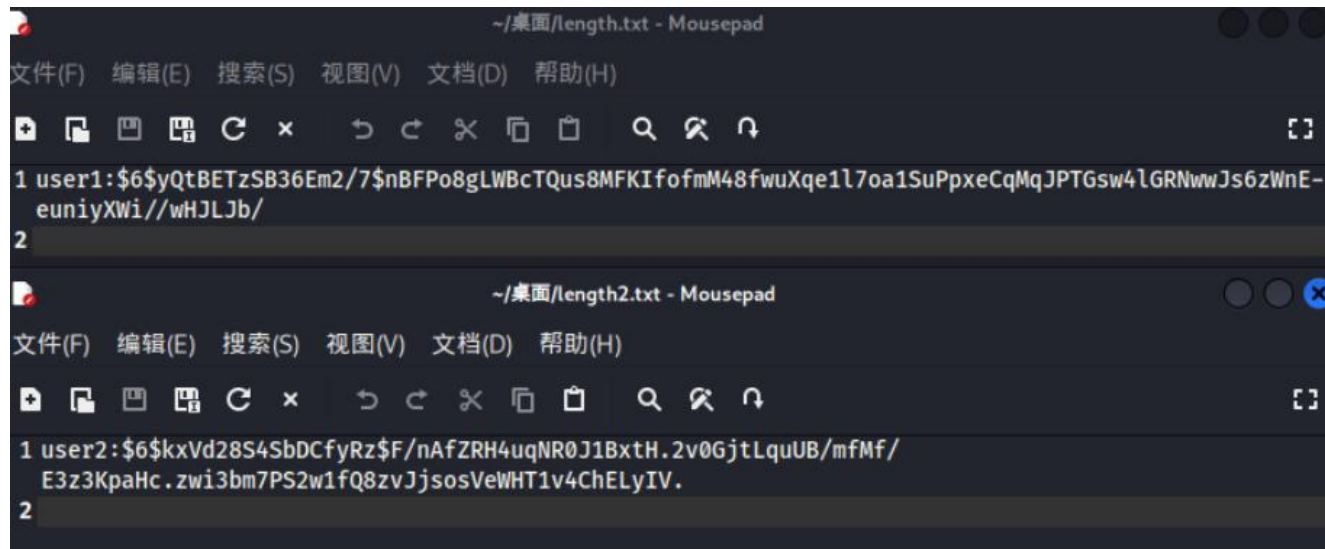
实验变量：自变量为密码长度（8位、10位、12位），字符类型保持一致（小写+数字）

观测指标：不同长度密码的暴力破解耗时、破解成功率

实验工具：Hashcat、John the Ripper、crunch

➤ Exercise

实验步骤：生成不同长度测试密码→配置暴力破解参数→启动破解工具→记录数据→分析长度与破解难度的关系



The image shows two screenshots of a text editor window titled "length.txt - Mousepad" and "length2.txt - Mousepad". The first window contains a long, complex password string. The second window contains a shorter password string. Both windows show a menu bar with options like "文件(F)", "编辑(E)", "搜索(S)", "视图(V)", "文档(D)", and "帮助(H)".

```
1 user1:$6$yQtBETzSB36Em2/7$nBFPo8gLWBcTQus8MFKIfofmM48fwuXqe1l7oa1SuPpxeCqMqJPTGsw4lGRNwwJs6zWnE-  
euniyXWi//wHJLJb/  
2
```

```
1 user2:$6$kxVd28S4SbDCfyRz$F/nAfZRH4uqNR0J1BxtH.2v0GjtLquUB/mfMf/  
E3z3KpaHc.zwi3bm7PS2w1fQ8zvJjsosVeWHT1v4ChELyIV.  
2
```

预期结果：密码长度每增加2位，破解耗时呈指数级增长，16位密码远超工具破解极限

For every 2 digits increase in password length, the cracking time increases exponentially, with 16 digit passwords far exceeding the tool's cracking limit

密码长度对比实验结果

Comparison experiment results of password length

8位密码破解用时

```
$ time john --wordlist=/usr/share/wordlists/rock
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$
Cost 1 (iteration count) is 5000 for all loaded ha
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key
aa123456 (user1)
1g 0:00:00:13 DONE (2026-03-27 09:44) 0.07457g/s 2
Use the "--show" option to display all of the crack
Session completed.

real    14.23s
user    26.66s
sys      0.52s
cpu     190%
```

密码长度仅增加了2位，破解耗时呈指数级增长

10位密码破解用时

```
Warning: detected hash type "sha512crypt", but the stri
Use the "--format=HMAC-SHA224" option to force loading
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA5
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for
aa12345678 (user2)
1g 0:00:12:30 DONE (2026-03-27 09:57) 0.001332g/s 2768p
Use the "--show" option to display all of the cracked p
Session completed.

real    751.09s
user    1441.10s
sys      2.60s
cpu     192%
```

The password length has only increased by 2 digits, and the cracking time has grown exponentially

3.密码复杂度对比实验

Password complexity comparison experiment

实验目的：验证字符复杂度对密码安全的提升作用

Experimental objective: To verify the enhancing effect of character complexity on password security

实验变量：自变量为字符类型（纯数字、纯小写、小写+数字、小写+大写+数字+符号），密码长度统一为8位

观测指标：不同复杂度密码的暴力破解耗时、破解成功率

实验工具：Hashcat、John the Ripper、crunch

Exercise

实验步骤：分组生成测试密码→采用相同字典进行攻击→记录破解数据→对比分析复杂度影响

预期结果：字符类型越多，密码空间越大，破解难度越高，四类混合密码几乎无法被字典破解

Expected result: The more character types there are, the larger the password space, and the higher the difficulty of cracking. Four types of mixed passwords are almost impossible to be cracked by dictionaries

实验规范

- 实验环境：使用本地虚拟机，禁止在校园网、真实服务器上开展破解操作
 - 数据记录：**全程留存截图**、参数设置、耗时数据、日志文件，整理成表格
 - 重复实验：每组实验重复3次，排除偶然误差，提升数据可信度
-
- Experimental environment: Use local virtual machines and prohibit cracking operations on campus networks and real servers
 - Data recording: retain screenshots, parameter settings, time consumption data, and log files throughout the process, and organize them into tables
 - Repeated experiments: Each experiment is repeated 3 times to eliminate accidental errors and improve data reliability

准备环境

准备环境

```
sudo apt update
```

```
sudo apt install john wordlists openssl -y
```

解压字典

```
sudo gzip -d /usr/share/wordlists/rockyou.txt.gz
```

密码生成脚本

```
#!/bin/bash
```

```
# 清空旧文件
```

```
> test.txt
```

```
# 弱密码
```

```
echo "weak1:$(openssl passwd -6 123456)" >> test.txt
```

```
echo "weak2:$(openssl passwd -6 admin)" >> test.txt
```

```
echo "weak3:$(openssl passwd -6 password)" >> test.txt
```

```
# 强密码（注意引号）
```

```
echo "strong1:$(openssl passwd -6 'T9#kLp2@vX1q')"
```

```
echo "Hash生成完成，已写入 test.txt"
```

关键命令解释

Explanation of key commands:

```
openssl passwd -6 123456
```

该命令通过 OpenSSL 工具，采用 SHA-512 算法（参数 - 6 指定）对明文密码进行加盐哈希计算，生成可安全存储、不可逆向还原的加密密码串。

```
time john --wordlist=/usr/share/wordlists/rockyou.txt test.txt
```

time 统计命令执行时间，john 调用密码破解工具，通过 rockyou.txt 字典文件对 test.txt 中的加密密码进行字典攻击，用于验证弱密码可被快速破解。

Explanation of key commands:

```
john --clear
```

```
rm ~/.john/john.pot
```

清除缓存

```
john --wordlist=/usr/share/wordlists/rockyou.txt --max-run-time=86400 test_hashes.txt
```

最多跑 24 小时，观察强密码是否仍未被破解

```
john --show test_hashes.txt | grep -v ':$'
```

查看已破解密码

5 客观论证 (Objective Justification)

5.1 实验结果高效使用

- 数据可视化：将实验耗时、成功率整理为表格、或折线图、柱状图，直观展示对比差异
- 结论对应：每条实验结论精准匹配一条密码策略，如“12位密码破解耗时远高于8位，支撑最小12位长度规则”
- 误差分析：简要说明实验局限性（工具算力、字典大小、测试环境），体现学术严谨性
- 数据解读：不只是罗列数据，需分析数据背后的安全规律，解释策略设计的合理性

Data visualization: Organize the experiment time and success rate into tables, line charts, and bar charts to visually display the differences in comparison

Conclusion correspondence: Each experimental conclusion accurately matches a password strategy, such as "12 bit password cracking takes much longer than 8 bits, supporting the minimum 12 bit length rule"

Error analysis: Briefly explain the limitations of the experiment (tool computing power, dictionary size, testing environment), reflecting academic rigor

Data interpretation: It is not just about listing data, but also analyzing the security rules behind the data and explaining the rationality of strategy design

5.2 文献支持引用规范

权威来源：NIST SP 800-63B密码标准、ISO27001信息安全体系、密码安全学术论文、行业安全报告

引用场景：策略设计依据、攻击原理说明、密码强度理论、实验方法参考

Authoritative sources: NIST SP 800-63B Password Standard, ISO27001 Information Security System, Academic Papers on Password Security, Industry Security Reports

Reference scenarios: Strategy design basis, attack principle explanation, password strength theory, experimental method reference

5.3 分析与解释逻辑

遵循固定论证逻辑：呈现实验数据→总结实验规律→关联密码策略→阐述安全价值→回应作业目标。
先证明“强密码/长密码/复杂密码更安全”，再说明“为何设计当前密码策略”，最后论证“该策略可有效降低密码安全风险”。

Following a fixed logic of argumentation: presenting experimental data → summarizing experimental patterns → associating password strategies → elaborating on security values → responding to homework objectives. First, prove that "strong passwords/long passwords/complex passwords are more secure", then explain "why the current password strategy is designed", and finally argue that "this strategy can effectively reduce password security risks".

6 Reflection 写作指南

6.1 实验体验

描述实验全过程的真实感受，包括工具上手难度、变量控制细节、数据采集过程、操作心得，体现实操过程中的思考，例如：“初次使用John the Ripper时对参数配置不熟悉，通过查阅官方文档逐步完成环境搭建，深刻理解了密码破解的底层逻辑”。

Describe the real experience of the entire experiment process, including the difficulty of getting started with the tools, details of variable control, data collection process, and operational experience, reflecting the thinking in the practical process. For example, "I was not familiar with parameter configuration when I first used John the Ripper, but gradually completed the environment setup by consulting official documents, and deeply understood the underlying logic of password cracking."

6.2 问题与挑战

详细说明实验和写作中遇到的具体问题，以及解决过程，体现问题解决能力：

实验类：工具安装报错、变量控制不当、数据误差较大、破解效率过低

写作类：策略逻辑梳理混乱、论证缺乏数据支撑、报告结构不清晰

表述要求：写明“问题+原因+解决方法+收获”，例如“实验中因未控制字符变量导致数据无效，后续重新分组实验，掌握了对照实验的设计核心”

Provide a detailed explanation of the specific problems encountered in the experiment and writing, as well as the process of solving them, demonstrating problem-solving skills

Experimental category: tool installation errors, improper variable control, large data errors, low cracking efficiency

Writing category: Chaotic sorting of strategic logic, lack of data support for argumentation, unclear report structure

Requirement for expression: Clearly state "problem+reason+solution+gain", for example, "In the experiment, data was invalid due to uncontrolled character variables, and subsequent experiments were reorganized to master the design core of the control experiment"

6.3 学习收获

结合课程理论与实践，总结知识、技能、思维层面的收获，例如：掌握了密码安全策略设计规范、理解了常见密码攻击原理、提升了实验设计与学术论证能力、意识到安全与易用性平衡的重要性。

Combining course theory and practice, summarize the gains in knowledge, skills, and thinking, such as mastering the design specifications of password security strategies, understanding common principles of password attacks, improving experimental design and academic argumentation abilities, and realizing the importance of balancing security and usability.

6.4 改进方向

针对本次作业的不足，提出可落地的优化思路，例如：优化实验参数提升数据精准度、补充更多维度的密码实验、结合企业场景完善策略细节、学习更专业的密码安全工具等。

In response to the shortcomings of this assignment, practical optimization ideas are proposed, such as optimizing experimental parameters to improve data accuracy, supplementing more dimensions of password experiments, combining enterprise scenarios to improve strategy details, and learning more professional password security tools.

7 攻击类型分析

7.1 暴力破解 (Brute Force Attack)

暴力破解是最基础的密码攻击方式，攻击者通过枚举所有可能的字符组合，逐一尝试登录，直到匹配正确密码。破解耗时与密码长度、复杂度直接相关，短密码、低复杂度密码极易被破解。防御核心：提升密码长度、增加复杂度、设置账户锁定机制。

7.2 字典攻击 (Dictionary Attack)

字典攻击是暴力破解的优化版，攻击者不枚举所有组合，而是调用预设的弱密码字典、常用词汇字典进行尝试，效率远高于纯暴力破解。针对用户常用密码、生日、姓名等定制字典，破解成功率极高。防御核心：禁止弱密码、杜绝个人信息嵌入密码、增加字符复杂度。

7.3 凭证填充 (Credential Stuffing)

凭证填充是利用数据泄露后的账号密码对，在其他平台批量尝试登录，利用用户“一套密码通用”的习惯进行攻击。即使密码强度高，若多平台复用，仍存在极高被盗风险。防御核心：禁止密码重用、开启多因素认证、定期更换密码。

8 额外实验设计

额外实验是加分项，需具备创新性、可行性，无需复杂操作，以下提供自主实验思路：

多场景密码爆破攻击模拟实验：

Multi scenario password explosion attack simulation experiment:

实验目的： 模拟攻击者视角，验证弱口令风险及不同登录场景下的爆破防护机制有效性

Experimental objective: To simulate the attacker's perspective, verify the risk of weak passwords, and evaluate the effectiveness of explosion protection mechanisms in different login scenarios

实验环境：

靶机：WEB登录框 / SSH服务 / RDP远程桌面（任选其一或多场景对比）

攻击机：Kali Linux + 爆破工具（Hydra/Burp Suite/Metasploit）

实验步骤：

Experimental steps:

1. 环境搭建 → 部署靶机服务，配置测试账户（弱口令/强口令各一组）
2. 信息收集 → 识别登录接口参数（POST表单/SSH端口/RDP端口）
3. 字典准备 → 准备弱口令字典（top100/common passwords）
4. 爆破执行 → 使用工具进行自动化密码尝试，记录响应特征
5. 防护测试 → 开启账户锁定/验证码/失败延迟后再次测试
6. 结果分析 → 对比不同场景的爆破成功率、耗时及触发防护情况

Explanation of key commands:

```
hydra -l root -P passwords.txt ssh://127.0.0.1
```

使用 Hydra 对 SSH 服务进行爆破，指定单个用户名 root，使用 passwords.txt 作为密码字典

```
hydra -L users.txt -P passwords.txt ssh://127.0.0.1
```

使用 Hydra 对 SSH 服务进行批量爆破，从 users.txt 读取用户名列表，passwords.txt 读取密码字典

```
hydra -l administrator -P passwords.txt -s 3389 -t 4 rdp://127.0.0.1
```

使用 Hydra 对 RDP 服务爆破，指定端口 3389 并设置 4 个线程提高爆破效率

Explanation of key commands:

爆破web服务：

使用 Burp Suite 的 Intruder 模块，先拦截登录请求并发送到 Intruder，设置用户名/密码参数位置并导入字典，选择攻击模式后启动爆破并根据响应长度或状态码判断成功登录。

Results

Positions

Payloads

Resource pool

Settings

Filter: Showing all items

Request	Payload	Status code	Error	Timeout	Length ^	Comment	
10	123456a	200	☐	☐	1524		
11	123456789a	200	☐	☐	1524		
12	147258369	200	☐	☐	1524		
13	zxcvbnm	200	☐	☐	1524		
14	987654321	200	☐	☐	1524		
15	12345678910	200	☐	☐	1524		
16	abc123	200	☐	☐	1524		
17	qq123456789	200	☐	☐	1524		
18	123456789.	200	☐	☐	1524		
19	7708801314520	200	☐	☐	1524		

Example of password explosion protection mechanism

密码爆破防护机制示例

登录系统 (带审计防御)

用户名

密码

登录

用户名或密码错误! (当前已连续失败 6 次)

[查看安全审计日志 \(教学用\)](#)

事件	描述
LOCKED	触发临时锁定, 剩余 49 秒
LOCKED	触发临时锁定, 剩余 55 秒
LOCKED	触发临时锁定, 剩余 58 秒
FAIL	尝试登录 111 失败 (当日累计: 5)
FAIL	尝试登录 1111 失败 (当日累计: 4)
FAIL	尝试登录 1111 失败 (当日累计: 3)
FAIL	尝试登录 1111 失败 (当日累计: 2)
FAIL	尝试登录 admin 失败 (当日累计: 1)

实验结论：

Experimental conclusion:

弱口令账户可在短时间内被爆破成功，证明强口令策略必要性

无防护机制场景下爆破成功率高，开启账户锁定/验证码后攻击效率显著下降

不同服务（Web/SSH/RDP）的日志记录与响应特征存在差异，需针对性防护

Weak password accounts can be successfully blasted in a short period of time, proving the necessity of strong password strategies

The success rate of blasting is high in scenarios without protective mechanisms, and the attack efficiency significantly decreases after opening account lock/verification codes

There are differences in the logging and response characteristics of different services (Web/SSH/RDP), and targeted protection is needed

9 报告标准结构

Report standard structure

- 1.Introduction（引言）：研究背景、密码安全现状、作业目的、研究意义
- 2.Password Policy（密码策略）：完整策略内容+Rule-Reason-Attack三段式阐述
- 3.Justification（客观论证）：实验数据、文献支撑、策略合理性分析
- 4.Reflection（反思）：实验体验、问题挑战、学习收获、改进方向
- 5.Additional Experiments（额外实验）：拓展实验设计、过程、结果、结论
- 6.Conclusion（结论）：总结研究成果、策略核心价值、研究局限性
- 7.References（参考文献）：规范格式罗列所有引用文献、标准、工具
- 8.Appendix（附录）：实验截图、原始数据、工具参数、日志、代码片段

10 课后任务

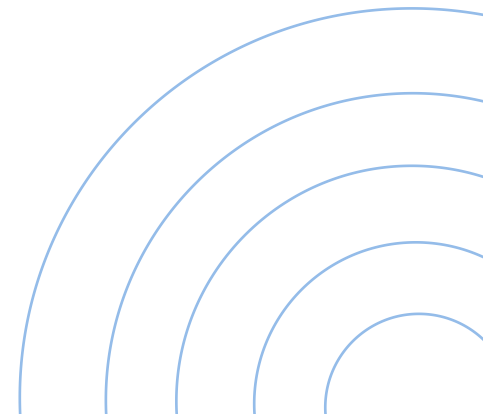
After-school assignment

按以下步骤推进作业，合理分配时间：

- 1.完成Password Policy编写：参照三段式模板，完善所有策略细则，确保逻辑严谨、覆盖全面
- 2.设计并执行实验：搭建实验环境、完成三组核心实验+一组额外实验，记录完整数据与截图
- 3.完成报告撰写：按标准结构填充内容，做好论证与反思，规范格式与参考文献
- 4.自查优化：核对评分标准、检查数据真实性、修正语法错误、完善附录内容



PART 03 | Study Plan



◆ 预估课程规划【北京时间】

学生可排课时间：北京时间周一至周日 10:00-20:00

课堂类型	对应阶段	课堂目的	课堂主题	时长
Lecture讲解	week4	针对周内容讲解相关知识点学习	Password Policy	2h
Lecture讲解	week4	针对周内容作业实验进行辅导答疑， 以及实验报告优化修改	Password Policy	1h
Lecture讲解	week5	针对周内容讲解相关知识点学习	AccessControl	*h
Lecture讲解	week5-week12	根据学生后续需求待定	根据学生后续需求待定	*h
总课时				3h